

S9L3

**ANALISI
MALWARE
WANNACRY
CON TRIAGE**



**TANCREDI
DE SIMONE**

1.Triage

1.1 Cos'è triage

Nel contesto della **Malware Analysis**, è importante capire la differenza tra analisi **statica** e **dinamica**.

L'analisi statica viene fatta **senza eseguire** un malware su una macchina, e comprende il prendere l'**hash** del file e utilizzare vari servizi come **Virus Total** per vederne le componenti, ma senza mai vederne i processi in azione.

L'analisi dinamica invece impone l'**esecuzione del Malware** su una macchina isolata che in gergo si definisce "**Sandbox**" ai fini di analizzare tutti i processi che il malware avvia quando viene eseguito. L'analisi dinamica è ovviamente più dettagliata, a volte i malware nascondono determinate informazioni del codice sorgente, quindi per avere un quadro completo è importante, soprattutto per malware non ancora conosciuti bene, eseguirli in sicurezza, **creare un'esplosione controllata**.

Triage serve proprio a questo, caricando un file sul sito lui avvierà una macchina virtuale sandbox che è molto brava a **fingersi una macchina reale** (a volte le nostre macchine virtuali non ingannano il malware in questo senso) per eseguirci sopra il malware, per poi creare un report dettagliato.

Oggi per esercitazione andremo ad analizzare con triage il malware **WannaCry** per capirne i processi e il funzionamento.

1.2 Report di triage, Prima Analisi Malware

Caricando il file .exe ho avviato l'analisi, il report ha evidenziato quanto segue:

Nome file originale: WannaCrypt0r.exe

Hash SHA256: ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa

Punteggio di minaccia: 10 / 10

Categoria / Tag: Ransomware, Worm, Trojan, Spyware

Processi Figli (Drop): taskdl.exe, taskse.exe, tasksche.exe, taskhsvc.exe

Estensione File Cifrati: .wnry

Porta Proxy TOR Locale: 127.0.0.1:9050

Chiave di Registro per Persistenza: HKLM\...\Run\zxxtirgju047

Immagine di Defacement: @

Il malware presenta un punteggio di pericolosità di **10/10**, confermando la sua natura malevola e la sua capacità di compromettere interamente la disponibilità e la riservatezza dei dati sul target.

Analisi Tecnica del Funzionamento

Il malware opera attraverso diverse fasi critiche, dalla persistenza all'impatto finale sui file dell'utente.

1. Evasione delle Difese e Persistenza

Appena eseguito, il malware mette in atto diverse strategie per garantire la propria sopravvivenza nel sistema:

- **Modifica dei permessi:** Utilizza **icacls.exe** per concedere il **controllo totale** (Everyone:F) sulla directory corrente, assicurandosi di poter manipolare i file senza restrizioni.
- **Persistenza nel Registro:** Aggiunge una chiave di esecuzione automatica (Run key) nel registro di Windows (HKLM\...\Run\zxxtirgju047) che punta a **tasksche.exe**, garantendo il riavvio del malware ad ogni accesso al sistema.
- **Attributi dei file:** **Imposta i propri file come nascosti** e di sistema tramite il comando `attrib +h +s` per complicare la rimozione manuale.

2. Inibizione del Recupero del Sistema

Per costringere la vittima al pagamento, WannaCry blocca ogni possibilità di ripristino autonomo dei dati:

- **Cancellazione delle Shadow Copies:** Esegue il comando **vssadmin delete shadows /all /quiet** e utilizza le API COM del servizio Volume Shadow Copy per **eliminare i backup locali di Windows**.
- **Disabilitazione del ripristino all'avvio:** Utilizza `bcdedit` per ignorare gli errori di avvio e disabilitare l'ambiente di recovery di Windows.

3. Componente Ransomware e Impatto Visivo

Il "core" del malware è focalizzato sulla cifratura dei dati:

- **Cifratura Multilingue:** Il report evidenzia il drop di numerosi file **.wnry** in varie lingue (italiano, inglese, russo, ecc.), che contengono le **istruzioni per il riscatto** da mostrare alla vittima.
- **Defacement del Desktop:** Il malware modifica il registro di sistema per cambiare lo sfondo del desktop con un'immagine (@WanaDecryptor@) che informa l'utente dell'avvenuta cifratura.

4. Capacità di Worm e Comunicazioni TOR

A differenza di un comune ransomware, questo campione include **funzionalità di rete avanzate**:

- **Modulo Worm:** Il tag worm e l'attività di discovery indicano la capacità di scansionare la rete per propagarsi lateralmente.
- **Infrastruttura TOR:** Il malware effettua il drop di un intero client TOR (tor.exe e relative DLL come ssleay32.dll, libevent-2-0-5.dll) per stabilire comunicazioni anonime con i server di

Command & Control (C2). Il traffico verso il nodo TOR è stato rilevato dai sensori Suricata.

Sintesi del Rischio

Il malware non si limita a cifrare i file (Ransomware), ma agisce anche come **Stealer/Spyware**, leggendo i dati dei profili dei browser web. La combinazione della cancellazione dei backup, della persistenza e della capacità di auto-propagazione lo rende una minaccia critica per qualsiasi infrastruttura aziendale.

1.3 Funzionamento nel dettaglio

Questo specifico campione di WannaCry mostra una **catena di esecuzione complessa** e altamente strutturata. Di seguito viene analizzato l'esatto flusso operativo, mappato secondo le tattiche del framework MITRE ATT&CK.

1. Esecuzione Iniziale e Manipolazione dei Privilegi (T1106 / T1055)

Il loader principale viene eseguito inizialmente dalla directory temporanea (**C:\Users\Admin\AppData\Local\Temp\WannaCrypt0r.exe**). Una volta avviato, il malware non si limita a cifrare i file dal proprio processo, ma implementa tecniche avanzate di **Process Injection** ed **escalation dei privilegi**:

- **Abuso dei Token (T1134)**: Attraverso lo strumento di gestione Windows WMIC.exe, il malware richiede l'elevazione e l'ottenimento di token di sistema critici, inclusi SeDebugPrivilege (necessario per ispezionare e iniettare codice in altri processi), SeTakeOwnershipPrivilege, SeBackupPrivilege e SeRestorePrivilege.
- **Process Injection via WriteProcessMemory (T1055.002)**: Il PID principale (4332) esegue massicciamente operazioni di scrittura direttamente nella memoria volatile di altri processi di sistema legittimi appena spawnati o esistenti, come attrib.exe, icacls.exe, cmd.exe e cscript.exe. Questa tecnica serve a mascherare le attività nocive sotto l'ombrello di binari fidati di Windows.

2. Evasione delle Difese e Preparazione dell'Ambiente (T1222 / T1564)

Prima di avviare il payload distruttivo, il malware si assicura il controllo assoluto del File System locale:

- **Sblocco dei Permessi ACL (T1222.001)**: Viene istanziato il comando **icacls.exe . /grant Everyone:F /T /C /Q**. Questo garantisce in modo ricorsivo (/T) e silenzioso (/Q) che qualsiasi utente (e quindi il malware stesso) disponga di permessi di **Controllo Totale** (Everyone:F) sulla cartella di esecuzione, aggirando eventuali restrizioni di sicurezza locali.
- **Occultamento degli Artefatti (T1564.001)**: Attraverso **attrib.exe +h .**, la directory di lavoro viene contrassegnata come nascosta. Viene inoltre eseguito l'**occultamento di directory critiche** (es. **attrib +h +s F:\\$RECYCLE**) per nascondere i propri moduli operativi all'utente.

3. Inibizione Totale del Ripristino di Sistema (T1490)

La fase più critica per garantire il successo del ricatto economico prevede l'annientamento di

ogni contromisura di disaster recovery locale. Il malware esegue una stringa di comandi concatenati estremamente aggressiva tramite cmd.exe:

```
vssadmin delete shadows /all /quiet & wmic shadowcopy delete & bcdedit /set {default} bootstatuspolicy ignoreallfailures & bcdedit /set {default} recoveryenabled no & wadmin delete catalog -quiet
```

Analizzando la telemetria di questa sequenza:

1. vssadmin delete shadows /all /quiet & wmic shadowcopy delete: Interrompono e cancellano i punti di ripristino di Windows (Volume Shadow Copies) sia tramite utility standard che invocando direttamente le API COM del servizio vssvc.exe.

2. bcdedit /set {default} bootstatuspolicy ignoreallfailures & recoveryenabled no: Modificano i dati di configurazione di avvio (BCD) istruendo il sistema operativo a ignorare i fallimenti di boot e a disabilitare completamente la schermata di ripristino automatico all'avvio.

3. wadmin delete catalog -quiet: Rimuove il catalogo dei backup di Windows, impedendo qualsiasi ripristino tramite i tool integrati nel sistema.

4. Ciclo di Vita dei Processi Drop e Persistenza (T1547.001)

Il malware agisce come un gestore di **sotto-moduli**, scaricando ed eseguendo (Drop) diversi binari specializzati nella cartella Temp:

- **taskdl.exe:** Utilizzato per la rimozione e la pulizia dei file temporanei durante il processo di cifratura.
- **taskse.exe:** Sfrutta il token SeTcbPrivilege (Act as part of the operating system) per elevare i permessi dell'eseguibile ed avviare sessioni interattive.
- **tasksche.exe:** Rappresenta il modulo deputato alla persistenza a lungo termine.
- **Persistenza nel Registro:** Per assicurarsi l'esecuzione persistente al boot, viene invocato reg.exe con i seguenti parametri:

```
reg add HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run /v "zxxtirgju047" /t REG_SZ /d "\"C:\Users\Admin\AppData\Local\Temp\tasksche.exe\""/f
```

Questo comando scrive una chiave di avvio automatico (Run Key) sotto il valore pseudo-casuale "zxxtirgju047".

5. Comunicazioni Internazionali e Infrastruttura di Rete TOR (T1573 / T1105)

Il report di triage evidenzia un'attività di rete estremamente specifica strutturata su due livelli:

A. Connessioni di Discovery e Beaconsing Esterno

Il malware effettua query DNS verso i server DNS pubblici (8.8.8.8) per risolvere domini Microsoft e Bing (g.bing.com, res.public.onecdn.static.microsoft). Queste connessioni HTTPS (porta 443) servono sia per **testare la connettività a Internet della macchina della vittima**, sia per tentare operazioni di discovery e download di librerie aggiuntive.

B. Tunneling TOR per il C2 (Command & Control)

La vera peculiarità risiede nel modulo taskshvc.exe, situato nella sotto-cartella TaskData\Tor\.

Questo binario avvia un proxy TOR locale sulla macchina infetta. La telemetria di rete cattura perfettamente questo comportamento:

- Il traffico viene instradato localmente verso l'indirizzo di loopback 127.0.0.1:9050 (la tipica porta d'ascolto del client TOR).
- Dal proxy locale, il malware si connette ai nodi di relay della rete TOR sparsi globalmente per agganciare i server C2 (es. IP monitorati in Francia 163.172.194.53:9001 e Olanda 192.87.28.82:9001).
- I sensori di rete Suricata intercettano questa attività generando l'alert critico: "Tor Node X.509 Certificate Pattern Detected - Inbound", confermando lo scambio di certificati crittografici tipici della rete Onion.

6. Cifratura e Impatto (T1486 / T1491)

Una volta stabilito l'ambiente, il ransomware avvia la cifratura massiva dei dati dell'utente, enumerando tutti i dispositivi di archiviazione fisici e logici connessi.

- **Identificazione della Lingua (T1614.001):** Prima di mostrare il riscatto, interroga la chiave di registro `\REGISTRY\MACHINE\SYSTEM\ControlSet001\Control\NLS\Language` per determinare la lingua del sistema operativo.
- **Drop dei file .wnry:** In base alla lingua rilevata, estrae i moduli di testo localizzati. Il report mostra il drop di file come `m_finnish.wnry`, `m_russian.wnry`, `m_spanish.wnry`, `m_turkish.wnry`, contenenti le istruzioni di pagamento. Il file di configurazione principale della cifratura viene salvato come `b.wnry` e `s.wnry`.
- **Modifica del Desktop (T1491.001):** Modifica direttamente i parametri dell'utente nel registro di sistema puntando alla chiave:

`\REGISTRY\USER\...\Control Panel\Desktop\Wallpaper`

Sostituisce lo sfondo originale con l'immagine bitmap generata dal malware:

`C:\Users\Admin\Desktop\@WanaDecryptor@`, completando il defacement visivo del sistema compromesso.

Conclusioni dell'Analisi

Questo sample rappresenta l'**architettura standard e spietata di WannaCry**: unisce la persistenza a livello di registro (Run key), l'evasione delle difese tramite sblocco delle ACL, l'iniezione di memoria, l'isolamento della macchina tramite distruzione dei backup, e un sistema di comunicazione C2 completamente anonimizzato su rete TOR. La presenza del tag worm e l'uso di script/comandi di rete indicano che il software è programmato per scansionare attivamente le subnet adiacenti alla ricerca di vulnerabilità (storicamente legate al protocollo SMBv1) per replicarsi in autonomia.